Harborlight Incident Summary — Plain-Language Briefing

2026-10-26 · Prepared by Divine Epie Ngol Esueh · Case HL-INC-2026-0204

What Happened

On 4 February 2026, a criminal group broke into Harborlight's computer network, copied business files, and then locked (encrypted) files and left ransom notes demanding payment. Staff discovered the notes that morning. No alarm went off, because nobody was watching the security logs. Our investigation rebuilt exactly what happened from those logs afterwards.

The short version: it started with one employee opening a fake "vendor invoice" file. Within about three hours the attackers controlled every computer in the office, including the main server that manages everyone's logins. They copied our shared files to an online storage account they control, locked files, and left 128 ransom notes. **They still had access at the end of the day**, so this is not over yet.

Timeline, in Plain Terms

When (4 Feb, UTC)	What Happened
About 2:25 AM	A fake invoice file is opened on a front-office computer. It quietly installs a hidden program that lets the attackers control that computer remotely.
2:42 AM	The attackers trick Windows into giving them full administrator control of that computer, without any warning pop-up.
Before 3:34 AM	They pull the employee's password out of the computer's memory.
3:34 AM	Using that password, they get into the file server where shared documents live.
4:04 AM	They delete the file server's built-in backups and recovery options, twice.
4:28 AM	They reach the main login server (the "domain controller") and copy the password database for every account.
Early morning	They upload our shared files to an online storage account they control.
5:18-5:20 AM	They erase security logs on all three computers to cover their tracks.
5:22 AM	They create their own hidden administrator account so they can come back.
After 5:22 AM	Files are locked and 128 ransom notes appear in shared folders.
Until at least 6:47 PM	The hidden programs keep "checking in" with the attackers all day. Access is still live.

What Was Taken, and What Was Damaged

- **Shared business files.** The contents of the shared folders on the file server were copied out to an attacker-controlled cloud storage account before anything was locked. This may include patient and insurance information.
- **Every password in the company.** The attackers copied the database that holds every staff and system account's password information. All passwords must be treated as known to the attackers.
- **Locked files.** Files on the shares were encrypted, and ransom notes were left 128 times.
- **Backups on the servers.** The file server's built-in recovery copies were deliberately deleted. The login server was only partly affected.

This is known as **double extortion**: the attackers can threaten both to keep files locked and to publish what they stole.

How the Attackers Got In

Think of it like a building with several weaknesses that lined up:

1. **A convincing fake delivery.** A file disguised as a vendor invoice was opened by an employee. Nothing blocked that type of file from running.
2. **Disguises.** The attackers' programs used the names of normal Windows programs (for example, the name of Microsoft's own antivirus engine), so they blended in.
3. **No internal walls.** Every computer could talk freely to every other computer. Once one was taken over, the rest were easy to reach.
4. **Passwords left in memory.** Windows kept a usable copy of the employee's password in memory, where the attackers could read it.
5. **Nobody watching.** Every step was recorded in the logs, but there was no monitoring or alerting to catch it while it happened.

This was not a case of an employee doing anything unusual. Opening an invoice is a normal part of the job. The fix is to make sure a single click can't lead to a company-wide breach.

Is It Over?

No. The attackers left three separate hidden programs that kept contacting them all day, plus a new administrator account they created for themselves. Until these are removed and every password is changed, the attackers can return at any time, including after the network is restored.

What We're Doing About It

Right now

- Disconnect all three computers from the network and block the attackers' internet addresses.
- Disable the attackers' account and change **every** password in the company, including system accounts.

- Remove the hidden programs, then rebuild the computers from clean copies rather than trying to clean them.
- Restore files from backups stored safely off the network.
- Assess whether patient or insurance data was in the stolen files and meet any legal notification duties. Contact law enforcement and cyber insurance.

To prevent a repeat

- Add internal "walls" so ordinary computers cannot directly reach the servers.
- Block risky attachment types and stop programs running from places they shouldn't.
- Turn on Windows protections that stop passwords being read from memory.
- Set up monitoring that alerts someone when logs are erased, admin accounts are created, or backups are deleted.
- Keep at least one backup copy offline or unchangeable, so it can't be deleted by an intruder.

Key Takeaway

The attackers needed one opened file and about three hours to take over the entire office, and every step was recorded but not watched. The most valuable improvements are not expensive: internal network separation, stronger password protection on each computer, safe offline backups, and someone, or something, actually watching the alerts.